M10

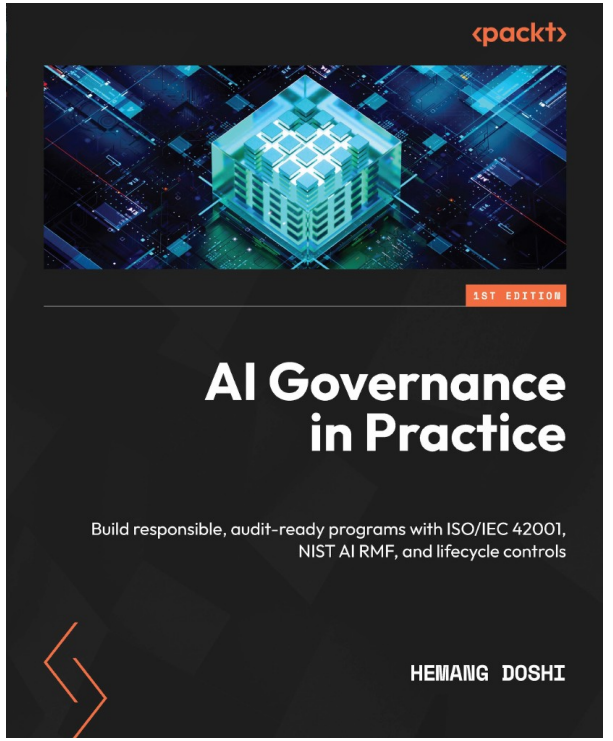
# Lifecycle, Incidents and Audit

Module 10 — Governing AI from idea to retirement, and proving it works

**307307 — BI Methods for Generative AI**

AI Governance · University of Petra

Lecturer: _____ Date: _____




*AI Governance in Practice — Hemang Doshi (Packt, 2026)*

# “Problem Solved!” Is Not the End

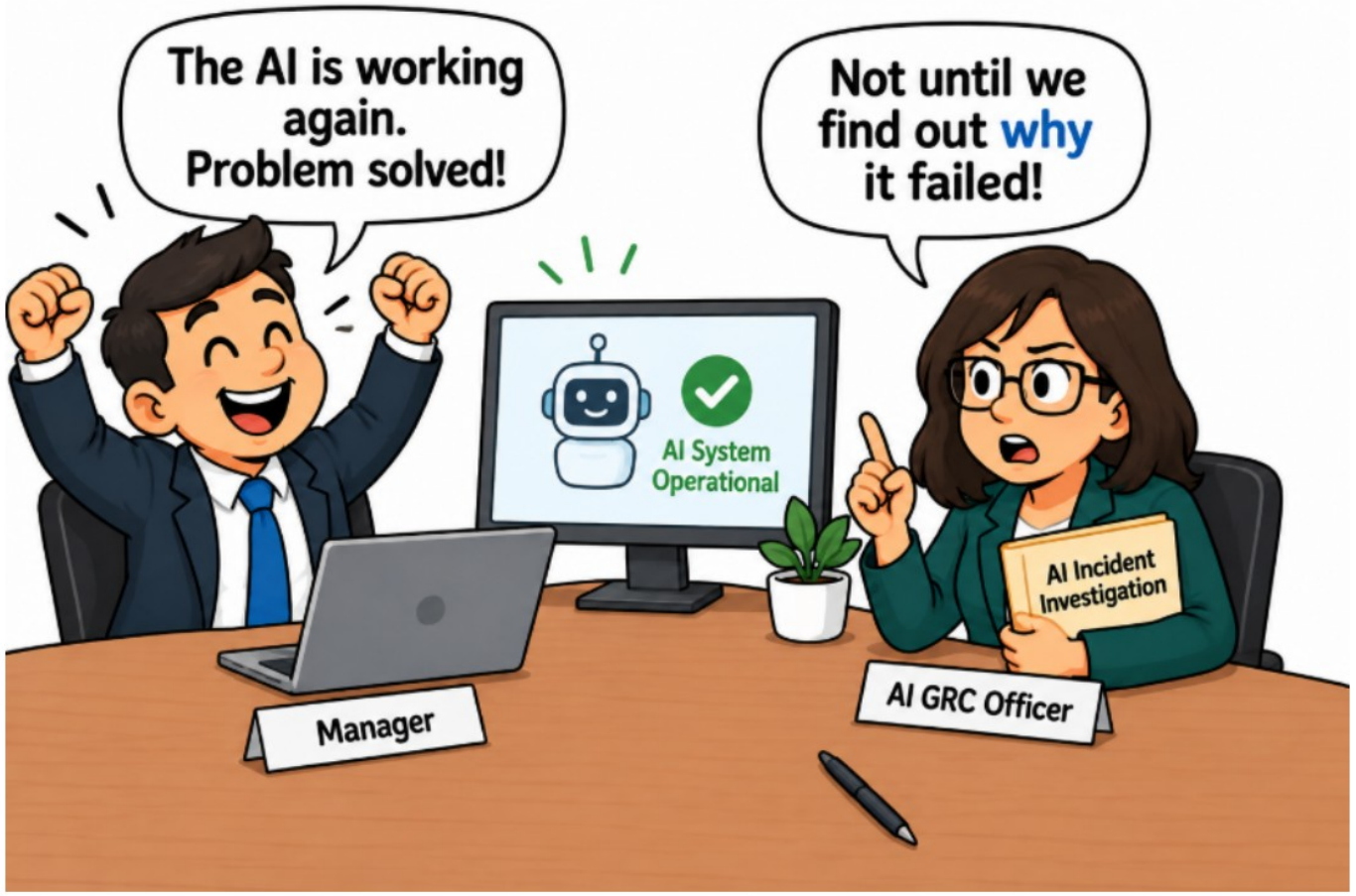



*Figure 16.1 from AI Governance in Practice (Hemang Doshi, Packt, 2026).*

## Fixing is not learning

Restarting a system removes the symptom. Unless we find the cause, the same failure can come back.

**Today:** the life of an AI system, what to do when it fails, and who checks that governance really works.

# What You Will Be Able to Do

1. **Describe** the seven stages of the AI lifecycle and the governance checkpoint at each one.
2. **Name** the main AI-specific security threats and the three things to protect: data, models and infrastructure.
3. **Recognize** an AI incident, rank its severity and follow the incident process, including the register.
4. **Explain** why an AI audit must be independent, what it examines, and what the AI GRC officer does (and does not do) during it.

# Seven Stages, One Governance Thread

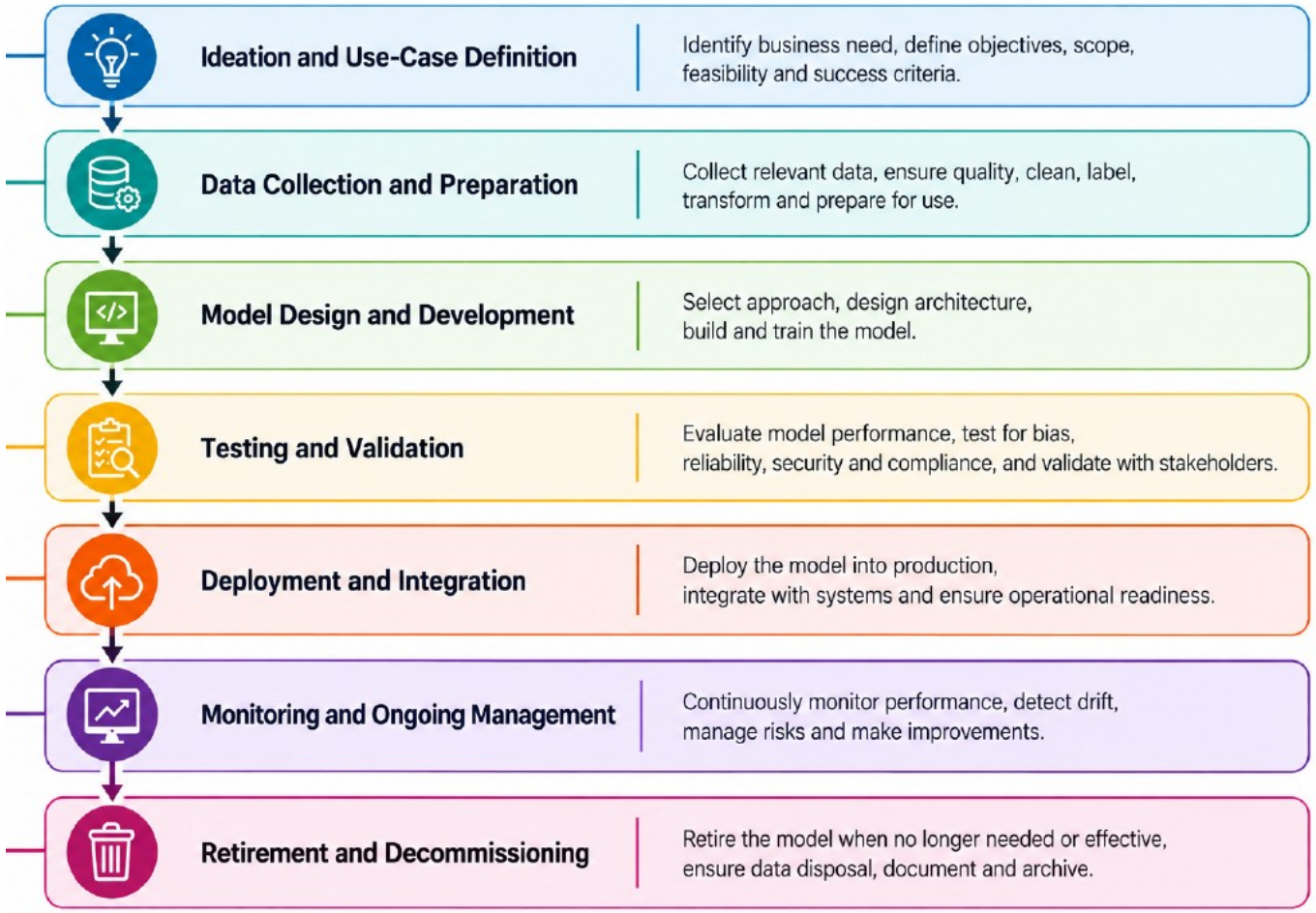



*Figure 14.2 from AI Governance in Practice (Hemang Doshi, Packt, 2026).*

## Governance is not a gate

It starts before the first line of code and continues after the system is switched off. Each stage has its own risks and its own checkpoint.

The book calls this an illustrative model. Other organizations may split or rename the stages.

# A Governance Checkpoint at Every Stage

| # | Stage | Governance checkpoint |
|---|---|---|
| 1 | **Ideation and use case** | Use-case proposal and approval; first risk classification; ethical and societal impact |
| 2 | **Data collection** | Data quality, privacy and consent checks; bias in the data |
| 3 | **Model design** | Documented design choices; explainability and security built in |
| 4 | **Testing and validation** | Independent testing (accuracy, bias, robustness); formal sign-off |
| 5 | **Deployment** | Go-live authorization; access control, logging, human oversight, transparency |
| 6 | **Monitoring** | Watch for drift and bias; incident process; approve retraining; re-check risk class |
| 7 | **Retirement** | Approved shutdown; data disposal; keep audit records; lessons learned; update inventory |

*Summarized from Chapter 14 of the book.*

# After Go-Live: Where Risk Grows

### 1 Drift

Real-world data changes, so accuracy slowly drops without any code change.

### 2 Bias review

Check regularly that outcomes stay fair for all groups, not only at launch.

### 3 Retraining

A retrained model is a changed model. It needs testing and approval first.

### 4 Reclassify the risk

A new use or feature can move the system into a higher risk class.

**Bought AI needs lifecycle control too.** For vendor systems the organization cannot see inside, so it relies on due diligence before buying, AI requirements in the contract, independent evidence such as an ISO/IEC 42001 certificate or audit report, and monitoring after go-live.

# New Threats That Target AI

| Threat | In plain words |
|---|---|
| **Data poisoning** | Bad data is slipped into the training data to make the model learn the wrong thing |
| **Adversarial attack** | Inputs crafted to fool a model, such as a sticker that makes a camera misread a sign |
| **Prompt injection** | Hidden instructions in text that make a chatbot ignore its rules |
| **Model theft or extraction** | Copying a model by sending it thousands of queries and studying the answers |
| **Model inversion** | Recovering private training data from what the model outputs |
| **AI supply chain attack** | A tampered pre-trained model, library or dataset is brought in from outside |
| **Denial of service** | Overloading the system so honest users cannot use it |

*Threat list from Chapter 15 of the book. Plain-language examples are ours.*

# Protect Data, Models and Infrastructure

## 1 Data

- Classify and limit access
- Encrypt and mask sensitive fields
- Check quality and track lineage
- Set retention and back up

## 2 Models

- Control access and versions
- Validate and security-test
- Approve every change
- Check outputs; retire safely

## 3 Infrastructure

- Keep an inventory; harden and patch
- Strong identity: MFA, least privilege
- Separate networks; log activity
- Keep the service available

**Who does what:** the CISO (chief information security officer) and security teams run the controls. The AI GRC officer makes sure AI-specific risks are covered and not forgotten.

# What Counts as an AI Incident?

### Definition

An event where an AI system behaves in a way that causes, or may cause, harm, noncompliance or significant risk.

**Do not wait for harm.** A near miss, such as a chatbot that leaks data but nobody noticed yet, is already an incident because it may cause harm. Repeated small problems also count.

1. **Criticality:** How important is the system?
2. **Severity:** How bad was or could the effect be?
3. **Data sensitivity:** Was personal or sensitive data involved?
4. **Regulation:** Is there a legal duty to report?
5. **AI-specific risk:** Bias, drift, poisoning, prompt injection?
6. **Recurrence:** Has this happened before?

# Turning “Serious” into Numbers

| Area | Example trigger for a higher severity |
|---|---|
| **Downtime** | A critical AI system is down for more than 30 minutes |
| **People affected** | 10 or more customers are affected |
| **Money** | Direct loss of USD 10,000 or more |
| **Performance** | Accuracy falls 10%, or the error rate rises 20% |
| **Data** | Any exposure of sensitive data |
| **Security** | Confirmed unauthorized access; a successful prompt injection that bypasses a control |
| **Compliance and governance** | A regulatory breach; an AI system deployed or changed without approval |

*Illustrative values based on Table 16.1 of the book. Each organization sets its own.*

## Why numbers?

Clear limits make decisions faster and fairer. Two people should reach the same severity.

**Some triggers need no number.** Any sensitive data exposure or confirmed unauthorized access is serious.

# The Incident Management Framework

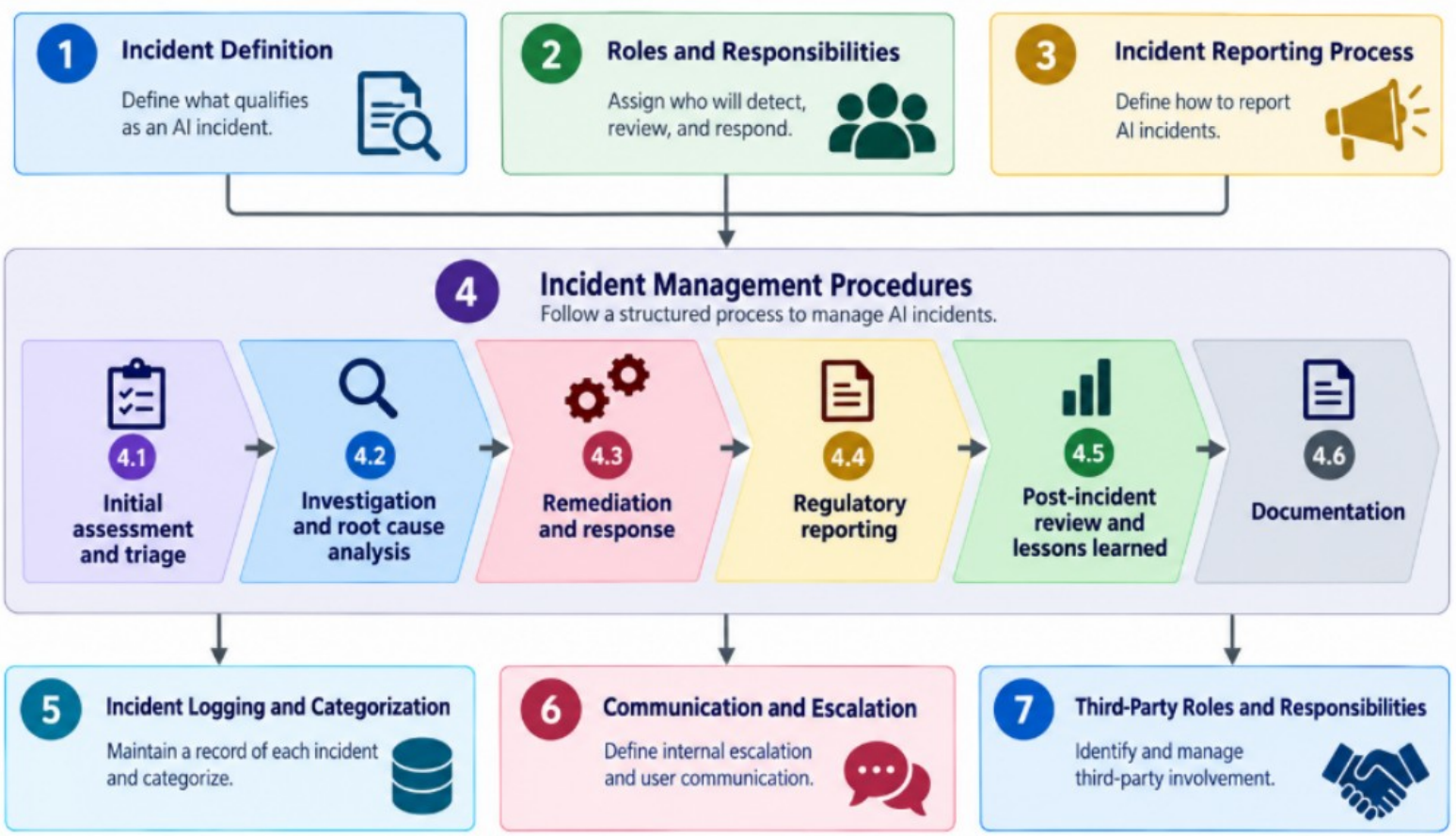



*Figure 16.2 from AI Governance in Practice (Hemang Doshi, Packt, 2026).*

## Use what exists

Join the IT, cyber and privacy incident process. Do not build a separate one.

**AI GRC role:** makes sure AI risks, rules and lessons are covered at each step.

# The Incident Process in Six Steps

### 1 Triage

Log it, judge severity, decide who must be told

### 2 Investigate

Find the root cause, not only the symptom

### 3 Respond

Contain the harm, fix, and check the fix works

### 4 Report

Check legal and contract duties to notify

### 5 Review

Hold a post-incident review; write down lessons

### 6 Document

Keep the evidence and update the register

Procedures 4.1–4.6 in Figure 16.2. Lessons should change policies, risk assessments, controls, monitoring or training.

# The Incident Register

| Field | Example entry |
|---|---|
| **ID and date** | INC-014 · 12 March, 10:20 |
| **Category** | AI – Accuracy (tagged as an AI incident) |
| **Affected system** | Study Buddy chatbot |
| **Description** | Wrong exam date given to 40 students |
| **Severity** | High (10 or more people affected) |
| **Owner** | Head of Student Services |
| **Root cause** | Old timetable left in the chatbot's sources |
| **Corrective action** | Add a review step · owner IT · due 30 April |
| **Status** | Open |

*Invented campus example. Fields based on Table 16.2 of the book.*

## One common register

AI incidents go in the same register as other incidents, tagged as AI, such as "Cybersecurity – AI".

**Review it often:** repeat incidents, overdue actions, repeated control failures.

# Common Incident Pitfalls

### 1 No clear definition

Staff cannot tell what to report

### 2 A separate process

AI is handled apart from IT, cyber and privacy

### 3 Delayed reporting

People wait until the harm is obvious

### 4 A technical-only view

Fairness, legal and people impact are missed

### 5 Unclear roles

Everybody thinks someone else is in charge

### 6 Closing without root cause

The same failure returns later

### 7 Untracked actions

Fixes have no owner or due date

### 8 Ignoring third parties

Vendors are not bound to notify or help

*Selected from Chapter 16 of the book, which also provides a checklist.*

# Why an Independent Audit?




*Figure 17.1 from AI Governance in Practice (Hemang Doshi, Packt, 2026).*

## The hospital case

Everything is in place on paper. Overall accuracy looks fine. An independent review could still find that results are much worse for one patient group.

AI audits look deeper than IT audits: type of AI, training data, model behavior, explainability, human oversight, monitoring.

**Self-review is a conflict of interest.** The people who build and run controls should not be the only ones who judge them.

# Who Audits, Who Supports

### 1 Audits

Internal audit, led by the Chief Audit Officer (CAO). An independent external assessor if AI skills are missing.

**Must be independent and qualified**

### 2 Supports

The AI GRC officer coordinates the audit, supplies documents, explains processes and tracks fixes.

**Must not audit their own controls**

### 3 Operates controls

System owners, technology leaders and the CISO run the controls that are tested.

**Provide evidence and fix findings**

The AI GRC officer helps audits succeed: covers AI risks in scope, links to regulations, keeps documents ready, tracks remediation and reports to leaders.

# What an AI Audit Examines

### 1 Governance and oversight

Policy, roles, inventory, approvals, committee minutes

### 2 Data quality and integrity

Sourcing, validation, cleansing, classification

### 3 Bias and fairness

Fairness testing and periodic reviews

### 4 Transparency and explainability

Tools and documents that explain decisions

### 5 Security

Access control, encryption, monitoring, secure development

### 6 Privacy and compliance

Privacy law, consent, data minimization

### 7 Model performance

Drift monitoring, testing, retraining controls

### 8 Human oversight

Clear ownership, escalation, ability to intervene

### 9 Incident management

Reporting, root cause, actions, lessons learned

*Based on Chapter 17 of the book. A full audit checklist is provided as Template 11 in the book.*

# How an Audit Works

1. Understand the control
2. Obtain evidence
3. Test the control
4. Find exceptions
5. Assess the risk
6. Document the finding
7. Agree corrective action
8. Follow up

## Internal audit

Done by the organization’s own internal audit function. Gives independent assurance to management and the committee. ISO/IEC 42001 requires internal audits.

## External audit

Done by an independent third party. Used when AI skills are missing, more independence is needed or the system is complex. ISO/IEC 42001 certification is an external audit.

# Key Takeaways

1. Governance follows AI through seven lifecycle stages, from idea to retirement. Each stage has a checkpoint.
2. AI adds new security threats, such as poisoning and prompt injection. Protect data, models and infrastructure.
3. An AI incident is any event that causes or may cause harm. Use clear thresholds, one common register and root cause analysis.
4. Close incidents only when the cause is fixed and the lessons are used.
5. An independent audit tests whether controls really work. The AI GRC officer supports it but never audits their own controls.

# Discussion and Activity

## Discuss

1. Why is retiring an AI system a governance task and not just an IT task?
2. Is a chatbot answer that was wrong but harmed nobody an incident? Why?
3. A small university has one person for AI governance. Who should audit?

## Activity

**When Study Buddy gave the wrong answer (a fictional case)**

A. Is it an incident? How severe?

B. Triage and escalate

C. Complete the register entry

D. Find the lifecycle gaps

E. Plan the independent audit

Groups of 3–4. Handout: Module10_Lifecycle_Incidents_Audit_activity.docx